Laboratory #10

Lab #10: Align an IT Security Policy Framework to the 7 Domains of a Typical IT Infrastructure

Learning Objectives and Outcomes

Upon completing this lab, students will be able to complete the following tasks:

- Define the policy statements for various IT security policy definitions
- Identify key elements of IT security policy definitions as part of a framework definition
- Reference key standards and requirements for IT security policy definitions needed for a framework definition
- Incorporate procedures and guidelines into an IT security policy definition example needed to fill a gap in a framework definition
- Create an IT security policy definition for a risk mitigation solution for an IT security policy framework definition

Required Setup and Tools

This is a paper-based lab. Internet access and the student's Microsoft Office applications are needed to perform this lab.

The following summarizes the setup, configuration, and equipment needed to perform Lab #10:

1. Standard onsite student workstation must have the following software applications loaded and Internet access to perform this lab:
    a. Microsoft Office 2007 or higher
    b. Adobe PDF reader
    c. Internet access

Recommended Procedures

Lab #10 – Student Steps

The following presents the steps needed to perform Lab #10 – Align an IT Security Policy Framework to the Seven Domains of a Typical IT Infrastructure:

1. Review your Lab #9, Part B deliverables and IT security policy framework definition

Copyright © 2013 by Jones & Bartlett Learning, LLC, an Ascend Learning Company
www.jblearning.com All Rights Reserved.

2. Review the gap analysis performed and which policy definitions you selected to fill those identified gaps in the overall IT security policy framework definition, Lab #9, Part B – Policy Framework Definition Gap Analysis
3. Review Lab #10, Part A – Align an IT Security Policy Framework to the Seven Domains of a Typical IT Infrastructure – Create Policy Statements
4. Define policy definition statements for the list of policy definitions in Lab #10, Part A – Align an IT Security Policy Framework to the Seven Domains of a Typical IT Infrastructure – Create Policy Statements
5. Review the key elements of the IT security policy template in Lab #10, Part B
6. Reference key standards and requirements for IT security policy definitions needed for a framework definition to cover all gaps
7. Incorporate procedures and guidelines into an IT security policy definition example needed to fill a gap in a framework definition
8. Create an IT security policy definition for one of the selected policy definitions to mitigate risk for an identified gap in the security policy framework definition
9. Answer the Lab #10 – Assessment Worksheets

Deliverables

1. Lab #10 – Assessment Worksheet, Part A – Policy Statements (This deliverable is required in lieu of submitting Lab Assessment Questions)
2. Lab #10 – Assessment Worksheet, Part B – Craft an IT Security Policy Definition

Evaluation Criteria and Rubrics

The following are the evaluation criteria and rubrics for Lab #10: Align an IT Security Policy Framework to the Seven Domains of a Typical IT Infrastructure that the student must meet:

1. Was the student able to define the policy statements for various IT security policy definitions? – [**20%**]
2. Was the student able to identify key elements of IT security policy definitions as part of a framework definition? – [**20%**]
3. Was the student able to reference key standards and requirements for IT security policy definitions needed for a framework definition? – [**20%**]

Copyright © 2013 by Jones & Bartlett Learning, LLC, an Ascend Learning Company
www.jblearning.com All Rights Reserved.

4. Was the student able to incorporate procedures and guidelines into an IT security policy definition example needed to fill a gap in a framework definition? – [**20%**]
5. Was the student able to craft an IT security policy definition for a risk mitigation solution for an IT security policy framework definition? – [**20%**]

Lab #10 – Assessment Worksheet

Part A – Policy Statement Definitions

Course Name:	**Policy Development in Information Assurance(IAP301)**
Student Name:	**Phạm Hoàng Hải Nguyên-SE180511** **Nguyễn Trúc Quỳnh- SE180280** **Giả Thị Nhã Trân- SE180405**
Instructor Name	**HaiH5**
Lab Due Date	**10/03/2026**

Overview

Create a policy statement that defines how these policies mitigate the risk, threat, or vulnerability as indicated in the gap analysis matrix below for each of the gaps identified and recommended policy definitions.

Risk – Threat – Vulnerability	IT Security Policy Definition
Unauthorized access from public Internet	**Network Security / Access Control Policy** – The organization must implement firewalls, intrusion detection systems, and network access control to prevent unauthorized external users from accessing internal systems. Only authenticated and authorized users are allowed to connect to the network.
User destroys data in application and deletes all files	**Data Protection and Backup Policy** – Critical organizational data must be protected through access control, regular backups, and monitoring. Only authorized users should have permission to modify or delete important files.
Hacker penetrates your IT	**Network Security and Vulnerability Management Policy** – The

infrastructure and gains access to your internal network	organization must regularly perform vulnerability scanning, penetration testing, and patch management to identify weaknesses and prevent unauthorized access to the internal network.
Intra-office employee romance gone bad	**Acceptable Use Policy (AUP)** – Employees must use company systems professionally and responsibly. The policy defines acceptable and prohibited use of IT resources to prevent misuse or abuse of organizational systems.
Fire destroys primary data center	**Disaster Recovery and Business Continuity Policy** – The organization must maintain backup data centers, disaster recovery plans, and regular data backups to ensure business operations continue after catastrophic events.
Communication circuit outages	**Business Continuity Policy** – Organizations must maintain redundant communication systems, backup internet connections, and failover network infrastructure to ensure system availability during network outages.
Workstation OS has a known software vulnerability	**Patch Management Policy** – All operating systems and applications must be updated regularly with the latest security patches to eliminate known vulnerabilities and protect the organization's IT environment.
Unauthorized access to organization-owned workstations	**Endpoint Security Policy** – All workstations must implement strong authentication, screen locking, antivirus protection, and device management to prevent unauthorized access.
Loss of production data	**Data Backup and Recovery Policy** – Organizations must perform regular data backups, maintain secure off-site storage, and test recovery procedures to ensure important data can be restored after loss.
Denial of service attack on organization e-mail server	**Incident Response and Network Security Policy** – The organization must deploy monitoring tools, intrusion detection systems, and traffic filtering to detect and mitigate denial-of-service attacks targeting email servers.

Risk – Threat – Vulnerability	IT Security Policy Definition
Remote communications from home office	**Remote Access Security Policy** – The organization must require secure remote connections using VPN and strong authentication methods to protect internal systems when employees work from home or external networks.
LAN server OS has a known software vulnerability	**Patch Management Policy** – All servers must be regularly updated with security patches and monitored for vulnerabilities to prevent exploitation of known software weaknesses.
User downloads an unknown e-mail attachment	**Email Security and Acceptable Use Policy** – Employees must not open unknown or suspicious email attachments. Email filtering, malware scanning, and user awareness training should be implemented to prevent malware infections.
Workstation browser has software vulnerability	**Endpoint Security and Software Update Policy** – All workstation applications, including web browsers, must be updated regularly and protected with endpoint security tools to reduce security risks.
Service provider has a major network outage	**Business Continuity and Service Availability Policy** – Organizations must maintain backup communication providers or redundant systems to ensure continuous network connectivity during service outages.
Weak ingress/egress traffic filtering degrades performance	**Network Security Policy** – The organization must configure firewalls, intrusion detection systems, and traffic filtering mechanisms to monitor and control incoming and outgoing network traffic.
User inserts CDs and USB drives with personal photos, music, and videos	**Removable Media / Acceptable Use Policy** – The use of external storage devices such as USB drives and CDs must be restricted or monitored to prevent malware infection and unauthorized data transfer.

VPN tunneling between remote computer and ingress/egress router	**VPN Security Policy** – All remote connections must use encrypted VPN tunnels with strong authentication to ensure secure communication between remote devices and the organization's network.
WLAN access points are needed for LAN connectivity within a warehouse	**Wireless Network Security Policy** – Wireless access points must use strong encryption (such as WPA2/WPA3) and proper authentication to secure wireless communications within the organization.
Need to prevent rogue users from unauthorized WLAN access	**Wireless Access Control Policy** – Network access control and authentication mechanisms must be implemented to ensure that only authorized users and devices can connect to the organization's wireless network.

For each identified gap, insert a recommendation for an IT security policy to help mitigate the risk, threat or vulnerability:

Define a policy statement (2 or 3 sentences max) for each of the following policy definitions that are needed to remediate the identified gap analysis for the IT security policy framework:

1. Access Control Policy Definition

The organization shall implement an access control policy to regulate who can access systems, applications, and sensitive data. Access must be granted based on the principle of least privilege and role-based access control to ensure users only access resources required for their job responsibilities. Strong authentication methods such as complex passwords and multi-factor authentication should be enforced. Access permissions must be reviewed periodically and revoked immediately when employees change roles or leave the organization.

Source: https://hw.glich.co/resources/glossary/access-control-policy

---

2. Business Continuity – Business Impact Analysis (BIA) Policy Definition

The organization shall conduct a Business Impact Analysis (BIA) to identify critical business processes and determine the impact of disruptions on operations. The analysis must evaluate financial, operational, and reputational consequences of system outages or disasters. Recovery priorities and acceptable downtime for critical systems must be clearly defined. The BIA results should be documented and reviewed regularly to ensure business continuity planning remains effective.

Source: https://www.paloaltonetworks.com/cyberpedia/what-is-an-it-security-policy

---

3. Business Continuity & Disaster Recovery Policy Definition

The organization shall establish and maintain a Business Continuity and Disaster Recovery (BC/DR) policy to ensure critical IT services can be restored quickly after disruptions. The policy must define recovery procedures, communication plans, and roles and responsibilities during emergencies. Disaster recovery testing should be conducted regularly to verify the effectiveness of recovery plans. This policy helps minimize downtime and ensures essential operations continue during incidents.

Source: https://encyclopedia.kaspersky.com/glossary/security-policy-document/

---

4. Data Classification Standard & Encryption Policy Definition

All organizational data must be classified according to its sensitivity and business value, such as public, internal, confidential, or restricted. Appropriate security controls must be applied based on classification levels, including encryption for sensitive data in storage and transmission. Access to confidential information must be limited to authorized personnel only. Regular audits must ensure that data handling and encryption standards are properly enforced.

Source: https://www.hackerone.com/knowledge-center/information-security-policy

---

5. Internet Ingress/Egress Traffic & Web Content Filter Policy Definition

All inbound and outbound internet traffic must pass through secure gateways such as firewalls and web filtering systems. These controls must monitor, log, and block unauthorized or malicious traffic entering or leaving the organization's network. Access to dangerous or inappropriate websites must be restricted through web content filtering solutions. Security tools must be updated regularly to defend against evolving cyber threats.

Source: https://www.paloaltonetworks.com/cyberpedia/what-is-an-it-security-policy

---

6. Production Data Back-up Policy Definition

The organization shall perform regular backups of all production systems and critical business data to prevent permanent data loss. Backup copies must be stored securely in separate locations and protected by appropriate access controls. Backup integrity must be tested periodically through restoration exercises. Backup schedules and retention policies must align with organizational and regulatory requirements.

Source: https://encyclopedia.kaspersky.com/glossary/security-policy-document/

---

7. Remote Access VPN Policy Definition

Remote access to internal organizational networks must only be permitted through secure VPN connections. All remote users must authenticate using strong credentials and multi-factor authentication to ensure identity verification. Data transmitted through VPN connections must be encrypted to prevent interception. Remote access permissions must follow the least-privilege principle and be monitored regularly.

Source: https://www.paloaltonetworks.com/cyberpedia/what-is-an-it-security-policy

---

8. WAN Service Availability Policy Definition

The organization shall maintain reliable WAN connectivity to ensure consistent communication between branch offices, data centers, and cloud services. Redundant network links and failover mechanisms must be implemented to minimize service interruptions. Network performance and availability must be monitored continuously to detect potential issues

early. Service providers must meet defined service level agreements (SLAs) to ensure network reliability.
Source: https://encyclopedia.kaspersky.com/glossary/security-policy-document/

---

9. Internet Ingress/Egress Availability (DoS/DDoS) Policy Definition

The organization shall implement protective measures to detect and mitigate denial-of-service (DoS) and distributed denial-of-service (DDoS) attacks. Network monitoring systems must analyze traffic patterns and trigger alerts when abnormal activity occurs. Traffic filtering, rate limiting, and automated mitigation tools must be used to protect network availability. Security teams must respond quickly to maintain uninterrupted service.
Source: https://www.paloaltonetworks.com/cyberpedia/what-is-an-it-security-policy

---

10. Wireless LAN Access Control & Authentication Policy Definition

All wireless networks within the organization must implement strong encryption protocols such as WPA2 or WPA3. Users connecting to wireless networks must authenticate using secure credentials and approved devices. Unauthorized devices and rogue access points must be detected and removed immediately. Wireless network usage must be monitored regularly to prevent unauthorized access.
Source: https://encyclopedia.kaspersky.com/glossary/security-policy-document/

---

11. Internet & E-Mail Acceptable Use Policy Definition

Employees must use organizational internet and email systems responsibly and only for legitimate business purposes. Accessing illegal, malicious, or inappropriate content is strictly prohibited. Users must not download unauthorized software or open suspicious email attachments that could introduce malware. Violations of this policy may lead to disciplinary action.
Source: https://en.wikipedia.org/wiki/Acceptable_use_policy

---

12. Asset Protection Policy Definition

The organization shall implement policies to protect all IT assets including hardware, software, and data from theft, damage, or unauthorized access. An inventory of all assets must be maintained and updated regularly. Physical and logical security controls must be applied to safeguard critical equipment and information resources. Employees are responsible for protecting the assets assigned to them.
Source: https://encyclopedia.kaspersky.com/glossary/security-policy-document/

---

13. Audit & Monitoring Policy Definition

The organization shall implement logging and monitoring systems to track activities across networks, systems, and applications. Security logs must be reviewed regularly to identify suspicious behavior or potential security breaches. Monitoring tools should provide real-time alerts for abnormal activity. Audit findings must be documented and used to improve the organization's security posture.
Source: https://www.paloaltonetworks.com/cyberpedia/what-is-an-it-security-policy

---

14. Computer Security Incident Response Team (CSIRT) Policy Definition

The organization shall establish a Computer Security Incident Response Team (CSIRT) responsible for responding to

cybersecurity incidents. The CSIRT must follow defined procedures for incident detection, containment, eradication, and recovery. All incidents must be documented and reported to relevant stakeholders. Lessons learned from incidents should be used to improve security controls and response processes.

Source: https://encyclopedia.kaspersky.com/glossary/security-policy-document/

---

15. Security Awareness Training Policy Definition

The organization shall provide regular security awareness training to employees to reduce human-related cybersecurity risks. Training must cover topics such as phishing attacks, password security, safe internet usage, and data protection. Employees must understand their responsibilities in protecting organizational information assets. Security awareness programs must be updated regularly to address emerging threats.

Source: https://www.hackerone.com/knowledge-center/information-security-policy

Lab #10 – Assessment Worksheet

Part B – Craft an IT Security Policy Definition

Course Name:	**Policy Development in Information Assurance(IAP301)**
Student Name:	**Phạm Hoàng Hải Nguyên-SE180511**
	Nguyễn Trúc Quỳnh- SE180280
	Giả Thị Nhã Trân- SE180405
Instructor Name	**HaiH5**
Lab Due Date	**10/03/2026**

Overview

In this lab, you are to create an organization-wide policy defining from the list provided in Lab #10 – Part A. Here is your scenario:

- Regional ABC Credit union/bank with multiple branches and locations throughout the region
- Online banking and use of the Internet is a strength of your bank given limited human resources
- The customer service department is the most critical business function/operation for the organization
- The organization wants to be in compliance with GLBA and IT security best practices regarding employees
- The organization wants to monitor and control use of the Internet by implementing content filtering

- The organization wants to eliminate personal use of organization owned IT assets and systems
- The organization wants to monitor and control use of the e-mail system by implementing e-mail security controls
- The organization wants to fill the gaps identified in the IT security policy framework definition
- Select one of the identified policy definitions from the gap analysis and define an entire IT

security policy

Instructions

Using Microsoft Word, create an IT security policy definition of your choice to mitigate the risks, threats, and vulnerabilities identified in the gap analysis. Use the following policy template:

ABC Credit Union

Access Control Policy Definition

Policy Statement

ABC Credit Union establishes an Access Control Policy to ensure that only authorized users can access organizational systems, applications, and data. Access to IT resources must be granted based on the principle of **least privilege** and **role-based access control (RBAC)**, ensuring users only receive permissions necessary to perform their job duties. All access requests, modifications, and revocations must be approved, documented, and regularly reviewed to prevent unauthorized access and protect sensitive financial information.

Purpose

The purpose of this policy is to protect the confidentiality, integrity, and availability of information systems within ABC Credit Union by controlling how users access IT resources. Unauthorized access to financial systems could lead to data breaches, fraud, or disruption of services, which makes strong access control essential.

Objectives of this policy include:

- Ensure that only authorized employees, contractors, or partners can access company systems and data.
- Reduce the risk of internal and external cyber threats by enforcing authentication and authorization controls.
- Implement the **least privilege principle**, ensuring users receive only the permissions necessary for their roles.
- Improve accountability through access logging, monitoring, and periodic access reviews.
- Address gaps in the organization's IT security framework by defining clear rules for granting, managing, and revoking access rights.

This policy helps mitigate risks such as insider threats, data leaks, and unauthorized system access.

Scope

This policy applies to all employees, contractors, third-party vendors, and partners who access ABC Credit Union's information systems. It also covers all IT assets including computers, servers, databases, mobile devices, and cloud services owned or managed by the organization.

The policy impacts several domains of a typical IT infrastructure including:

- **User Domain** – employees and users accessing systems.
- **Workstation Domain** – employee devices such as desktops and laptops.
- **LAN Domain** – internal corporate network access.
- **LAN-to-WAN Domain** – connections between internal and external networks.
- **Remote Access Domain** – employees accessing systems remotely via VPN.
- **System/Application Domain** – internal applications and databases.

All systems that store, process, or transmit sensitive financial data fall within the scope of this policy.

Standards

This policy supports technical standards and security frameworks that define how access control should be implemented. These standards may include authentication requirements such as strong passwords, multi-factor authentication (MFA), and secure login procedures.

The policy aligns with recognized information security standards such as **ISO/IEC 27002**, which recommends controlling user access to systems based on roles and ensuring authentication credentials are securely managed.

Examples of related standards include:

- Password complexity and rotation requirements
- Multi-factor authentication for privileged accounts
- Secure configuration standards for servers and applications
- Logging and monitoring standards for detecting unauthorized access attempts

These standards ensure consistent implementation of security controls across the organization.

Procedures

To implement this policy, ABC Credit Union will establish formal procedures for managing user access throughout the entire lifecycle of a user account. When a new employee joins the organization, the hiring manager must submit an access request specifying the systems required for the employee's job role. The IT department will review and approve the request before creating the user account.

User access rights must be reviewed periodically, especially when employees change roles or leave the organization. When employment is terminated, all associated accounts and permissions must be immediately revoked. Access logs will also be monitored regularly to detect suspicious activities or unauthorized attempts to access sensitive systems.

These procedures ensure the policy is consistently applied across the organization and reduce the likelihood of unauthorized access.

Guidelines

While implementing this policy, several challenges may arise such as user resistance to additional authentication steps, lack of awareness about security risks, or legacy systems that do not support modern authentication methods. To overcome these issues, ABC Credit Union will provide user training and security awareness programs explaining the importance of access control.

The organization will also gradually upgrade outdated systems to support stronger authentication and centralized identity management. Guidelines will encourage employees to follow secure practices such as protecting passwords, avoiding credential sharing, and reporting suspicious activity.

By following these guidelines, ABC Credit Union can ensure the effective implementation of access control while maintaining operational efficiency.

References

1. https://sprinto.com/blog/access-control-policy/
2. https://en.wikipedia.org/wiki/Role-based_access_control
3. https://en.wikipedia.org/wiki/ISO/IEC_27002